Seguridad, resiliencia y control humano (HITL)

Proyecto: Automatización de contenido y comunicaciones con Notion, Make, OpenAI, Gmail y Telegram. Fecha: 24 de octubre de 2026. Propósito: documentar controles del flujo, recuperación ante fallas y aprobación humana antes del envío.

1. Arquitectura y límites de confianza

El sistema opera en dos rutas separadas: generación (registro en Notion → recuperación de conocimiento → OpenAI → borrador en Notion) y envío (registro aprobado → validaciones → Gmail y/o Telegram → actualización de indicadores en Notion). Notion funciona como fuente de estado; Make orquesta las acciones.

Componente	Rol y superficie de riesgo
Notion	Contiene datos del registro, contenido generado, aprobación y banderas de envío. Riesgo: edición o exposición no autorizada.
Make	Ejecuta filtros, rutas y conectores. Riesgo: credenciales, reintentos y disparos repetidos.
OpenAI	Genera borradores desde instrucciones y contexto. Riesgo: contenido inexacto o divulgación de datos.
Gmail / Telegram	Canales de salida. Riesgo: destinatario incorrecto, duplicados o mensajes no aprobados.

2. Control humano HITL: regla de no envío sin aprobación

Etapa 1 — generación: un registro en estado Generando, con Aprobado = falso, entra en la ruta de IA. El resultado se guarda como Resumen_IA y el estado pasa a En revisión. Este paso no debe enviar mensajes.

Etapa 2 — revisión: una persona revisa el borrador directamente en Notion. Si lo acepta, establece Estado = Aprobado y Aprobado = verdadero. Si lo rechaza, mantiene la aprobación en falso y devuelve el registro para corrección; no debe habilitarse ninguna salida.

Etapa 3 — envío: Make vuelve a leer el registro y solo permite continuar cuando coinciden Estado = Aprobado, Aprobado = verdadero y existe contenido en Resumen_IA. La aprobación es una decisión humana persistida en Notion, no una aprobación automática del modelo.

3. Prevención de duplicados y bucles

Los filtros de salida revisan banderas por canal: Enviado_Gmail = falso y Enviado_Telegram = falso. Después de un envío correcto, la rama correspondiente actualiza su bandera en Notion. La ruta de generación exige el estado Generando y aprobación falsa, evitando regenerar contenido al modificar otros campos.

Limitación: una bandera actualizada después del envío reduce duplicados, pero no garantiza idempotencia estricta ante ejecuciones simultáneas o un fallo entre enviar y marcar. Como mejora se recomienda bloqueo por registro o clave idempotente y control de concurrencia.

4. Validaciones de salida

Canal	Condiciones y comportamiento documentado
Gmail	Destinatario dinámico tomado de Email en Notion. Requiere aprobación, borrador existente, correo presente y Enviado_Gmail = falso.
Telegram	Notificación interna dirigida a un chat configurado. La ruta actual incluye una restricción adicional por correo del registro; no es un canal de envío general a todos los clientes.

5. Resiliencia y gestión de errores

El flujo contempla un manejador tipo Break asociado a la generación con OpenAI, y manejadores de error en las ramas de envío. Los errores de comunicación se registran mediante actualizaciones en Notion, de forma que el problema pueda revisarse sin asumir un envío exitoso.

Falla	Respuesta operativa / verificación
OpenAI no responde	Conservar el registro sin aprobación; revisar la ejecución fallida en Make y reintentar conforme a la configuración efectiva del manejador Break.
Correo no enviado	No marcar Enviado_Gmail como verdadero; conservar información de error para diagnóstico.
Telegram no enviado	No marcar Enviado_Telegram como verdadero; registrar el fallo y comprobar el identificador de chat.
Registro incompleto	Detener la rama mediante filtros (correo, aprobación o texto faltante) y corregir los datos en Notion.
Disparo repetido	Verificar estado, aprobación y bandera del canal antes de ejecutar la salida.

6. Seguridad y protección de datos

Controles recomendados: otorgar acceso de edición a Notion solo a responsables; publicar únicamente vistas de demostración sin correos ni datos personales; mantener tokens y credenciales dentro de las conexiones protegidas de Make; evitar incrustar claves en el blueprint JSON o en GitHub; usar datos ficticios en capturas; aplicar mínimo privilegio a las integraciones.

Datos enviados al modelo: limitar el contexto a la información necesaria para redactar el mensaje; no incluir contraseñas, secretos, números de documento ni información sensible de clientes.

7. Plan de pruebas de aceptación

Caso	Entrada	Resultado esperado
T1: borrador	Generando + Aprobado falso	Se crea Resumen_IA; queda En revisión; sin envío.
T2: aprobación	Aprobado verdadero + Estado Aprobado	Gmail envía si existe Email y la bandera es falsa.
T3: rechazo	Aprobado falso / En revisión	No se envía por ningún canal.
T4: repetición	Enviado_Gmail verdadero	Se bloquea un segundo envío por Gmail.
T5: error	Fallo simulado de API o canal	Se registra error; no se marca como enviado.

8. Evidencia requerida y alcance de las afirmaciones

Adjuntar al repositorio: (a) blueprint exportado desde Make, (b) captura de los filtros y de la aprobación en Notion, (c) historial de al menos cinco pruebas con un rechazo y un error, y (d) dashboard de KPIs. Este documento describe la configuración conocida del flujo y los resultados esperados; no sustituye la evidencia de ejecución. Las medidas identificadas como “recomendadas” no deben presentarse como implementadas.

Conclusión: la separación entre generación, revisión humana y envío reduce el riesgo de mensajes no autorizados. Los filtros y las banderas por canal mejoran la resiliencia operativa; la verificación de ejecuciones y el control de concurrencia siguen siendo puntos importantes de seguimiento.